

AZ Herentals

Globale werking van het SOC
Grootte, Rollen, Tools en Werkwijze

Opleiding: Elektronica-ICT
Academiejaar: 2025/2026

Weyers Axel
Verbist Jef
Yoncalik Seyit Ali

Academiejaar: 2025-2026
Begeleiding: Tillemans David, Manderyck Isaac



AP HOGESCHOOL
ANTWERPEN

AP.BE

Gebruik van dit document

Dit document beschrijft de volledige werking van het Security Operations Center (SOC) van AZ Herentals. Het omvat de grootte, rollen, tools, processen en werkwijze van het SOC en vormt een centraal beleidsdocument ter ondersteuning van de dagelijkse SOC-operaties.

Als zorginstelling verwerkt AZ Herentals bijzonder gevoelige persoonsgegevens. Een professioneel ingericht en operationeel SOC is essentieel voor de bescherming van patiëntgegevens, de veiligheid van patiëntenzorg en de naleving van GDPR, NIS2 en de Belgische zorgwetgeving.

Houd altijd een offline/papieren kopie van dit document beschikbaar. Bij een actief cyberincident kunnen de normale ICT-systemen onbeschikbaar zijn.

Documentbeheer

Auteur	ICT Afdeling / ICT Manager
Eigenaar	Directie AZ Herentals
Aangemaakt op	Mei 2026
Laatst herzien door	Weyers Axel
Datum laatste herziening	5/25/2026

Versiebeheer

Versie	Datum	Goedgekeurd door	Beschrijving
1.0	Mei 2026	ICT Manager / Directie	Initiele versie

Inhoudsopgave

Gebruik van dit document	2
Documentbeheer	2
Versiebeheer	2
1. Inleiding en context.....	4
2. Doelstellingen van het SOC	4
3. Toepassingsgebied	4
4. Normen en kaders	5
5. Soort en grootte van het SOC.....	5
6. Rollen en verantwoordelijkheden	6
6.1 Interne rollen.....	6
Contactpunten voor het melden van cyberincidenten (24/7)	6
Cyber Incident Response Team (CIRT)	6
Managementteam (MT)	7
6.2 Externe partners.....	7
7. SOC infrastructuur en tools	7
7.1 Netwerksegmentatie en architectuur	8
7.2 Overzicht van de tools	8
8.1 Welke logs worden verzameld	9
8.2 Hoe worden logs verzameld	9
8.3 Dataflow van event tot alert	10
9. Monitoring en detectie	11
9.1 Dagelijkse monitoring.....	11
9.2 Detection rules en alerts	11
9.3 MITRE ATT&CK mapping	12
10. Escalatie en incidentrespons	12
10.1 Escalatiestructuur	12
10.2 Koppeling met het CIRP.....	13
11. Case management met DFIR-IRIS.....	13
12. Threat intelligence integratie	14
12.1 Strategische threat intelligence	14
12.2 Operationele threat intelligence	14
13. SOC werkwijze	14
13.1 Dagelijkse werkwijze	14
13.2 Wekelijkse vergadering	14
13.3 Periodieke taken	15
14. Rapportering en communicatie	15
15. Training en oefeningen	16
16. Definities en afkortingen	16

1. Inleiding en context

AZ Herentals is een regionaal ziekenhuis in de provincie Antwerpen dat medische zorg verleent aan een brede patiëntenpopulatie. Als zorginstelling verwerkt en beheert het ziekenhuis grote hoeveelheden gevoelige patiëntgegevens en is het afhankelijk van kritieke IT-systemen voor de dagelijkse werking. Dit maakt AZ Herentals een aantrekkelijk doelwit voor cyberaanvallen.

De zorgsector is de afgelopen jaren een steeds vaker doelwit van gerichte cyberaanvallen. Ransomware vormt de grootste bedreiging: aanvallers versleutelen systemen en eisen losgeld, terwijl de nood aan continue systembeschikbaarheid in een ziekenhuisomgeving levens kan bedreigen. Naast ransomware zijn phishing, datalekken en aanvallen op medische IoT-apparatuur reële dreigingen.

Om deze dreigingen het hoofd te bieden heeft AZ Herentals een Security Operations Center (SOC) opgericht. Het SOC vormt de centrale eenheid voor het detecteren, analyseren en beheersen van cyberdreigingen. Dit document beschrijft de volledige werking van dat SOC: van de organisatorische structuur en rollen tot de technische tools, processen en dagelijkse werkwijze.

De ICT-afdeling van AZ Herentals is een klein intern team. Voor gespecialiseerde taken bij ernstige incidenten werkt het team samen met externe partners zoals CERT.be en gespecialiseerde incident response bedrijven. Het SOC-model van AZ Herentals is dan ook een intern hybride SOC waarbij monitoring en incidentrespons worden gecombineerd binnen dezelfde rollen, aangevuld met externe expertise waar nodig.

2. Doelstellingen van het SOC

Het SOC van AZ Herentals heeft de volgende doelstellingen:

- Continu bewaken van de IT-infrastructuur op afwijkend gedrag en cyberdreigingen
- Tijdig detecteren van beveiligingsincidenten via automatische alerting en actieve monitoring
- Gestructureerd reageren op incidenten conform het Cyber Incident Response Plan (CIRP)
- Beschermen van patiëntgegevens en het waarborgen van de GDPR-compliance
- Garanderen van de continuïteit van kritieke zorgprocessen en IT-systemen
- Voldoen aan de wettelijke meldingsverplichtingen conform NIS2 en GDPR
- Continu verbeteren van de beveiligingshouding via “lessons learned” en regeloptimalisatie

3. Toepassingsgebied

Het SOC van AZ Herentals monitort en beschermt alle systemen, netwerken en gegevens die eigendom zijn van of beheerd worden door het ziekenhuis, inclusief systemen van derde partijen die in naam van het ziekenhuis worden verwerkt. Concreet omvat dit:

- SOC-netwerk (LAN 192.168.1.0/24): de beveiligingstools (Wazuh, DataGerry, DFIR-IRIS, OpenVas) op de AlmaLinux-server
- Kantoornetwerk (OPT1 192.168.10.0/24): de Active Directory Domain Controller en Windows-werkstations
- Netwerk perimeter: de pfSense firewall met Zeek netwerkinspectie
- Alle gebruikersaccounts en gedeelde mappen beheerd via Active Directory (domein: lab.local)
- Kritieke ziekenhuissystemen: EPD, HIS, PACS, LIS en medische IoT-apparatuur (monitoring en bewaking)
- Back-up- en herstelsystemen die essentieel zijn voor de bedrijfscontinuïteit

4. Normen en kaders

Het SOC van AZ Herentals is opgezet en opereert conform de volgende normen, richtlijnen en referentiekaders:

Kader / Norm	Toepassing voor het SOC
NIS2-richtlijn (EU) 2022/2555	Verplichte melding bij CCB/CERT.be: vroegtijdige waarschuwing binnen 24 uur, volledige melding binnen 72 uur bij significante incidenten.
AVG/GDPR (EU) 2016/679	Bescherming van patiëntgegevens. Meldplicht datalekken aan GBA binnen 72 uur (Art. 33). Melding aan betrokken personen indien hoog risico (Art. 34).
CyFun BASIC - CCB (2025)	Het CyberFundamentals Framework van het CCB als referentiekader voor NIS2-compliance. AZ Herentals behaalt maturiteitsscore 2,92/5 (BASIC COMPLIANT).
NIST SP 800-61 Rev. 2	Computer Security Incident Handling Guide. De zes NIST-fasen vormen de basis voor de SOC-werkwijze en de escalatiestructuur.
ISO/IEC 27035	Beheer van informatiebeveiligingsincidenten. Principes voor documentatie, onderzoek en lessons learned toegepast in de SOC-procedures.
MITRE ATT&CK Framework	Alle custom Wazuh-detectieregels zijn gemapped op het MITRE ATT&CK-framework voor gestandaardiseerde dreigingsclassificatie.
Belgische ziekenhuiswetgeving	Bewaring van medische dossiers en EPD-back-ups minimaal 10 jaar conform Belgische regelgeving.

5. Soort en grootte van het SOC

Het SOC van AZ Herentals is opgezet als een intern hybride SOC. Dit betekent dat het een kleine, interne IT-afdeling is die zowel de monitoring (detectie van dreigingen) als de incidentrespons (actieve reactie) combineert binnen dezelfde rollen. Er is geen strikte scheiding tussen een Tier-1-monitoringteam en een apart Tier-2-responseteam, zoals bij grote organisaties het geval is.

Dit model is bewust gekozen omdat AZ Herentals een regionaal ziekenhuis is met een beperkte ICT-afdeling. De kracht van dit model zit in de flexibiliteit en de snelle escalatie: een medewerker die een alert detecteert, kan direct doorgaan met het onderzoek of onmiddellijk de ICT Manager inschakelen.

Kenmerk	AZ Herentals SOC
SOC-type	Intern hybride SOC (monitoring en respons gecombineerd)
Interne bezetting	4 tot 5 medewerkers (inclusief gedeelde rollen)
Operationele uren	Kantooruren 08u00 tot 18u00 CET - automatische alerting buiten uren
24/7 dekking	Nee intern - kritieke alerts (Level 10+) worden automatisch doorgestuurd via e-mail en SMS naar de ICT Manager
Externe ondersteuning	Ja - CERT.be, externe IR-partners bij complexe of ernstige incidenten
Primaire SIEM	Wazuh (met OpenSearch Dashboards voor visualisatie)
Case management	DFIR-IRIS (via Docker Compose op AlmaLinux, poort 4433)
Asset management	DataGerry CMDB (via Docker Compose op AlmaLinux, poort 80)

6. Rollen en verantwoordelijkheden

Dit onderdeel beschrijft de rollen en verantwoordelijkheden van alle personen betrokken bij de werking van het SOC. Het CIRT (Cyber Incident Response Team) staat in voor de operationele werking. Het Managementteam (MT) neemt de strategische beslissingen bij significante incidenten. Alle medewerkers moeten vertrouwd zijn met hun verantwoordelijkheden en hun reactie regelmatig oefenen.

6.1 Interne rollen

Contactpunten voor het melden van cyberincidenten (24/7)

Naam	Beschikbaarheid	Rol	Verantwoordelijkheid
Tony Von	24/7	ICT Manager (primaire SPOC)	Eerste aanspreekpunt bij alle cyberincidenten. Leidt de CIRT-operaties.
Giro Van Sticht	24/7 (back-up)	ICT Helpdesk (back-up SPOC)	Back-up contactpunt bij afwezigheid van de ICT Manager.

Cyber Incident Response Team (CIRT)

Functie AZ Herentals	CIRT-rol	Bezetting	CIRT-verantwoordelijkheden
ICT Manager	Cyber Incident Manager	1 FTE(Full-Time Equivalent)	Operationele leiding over de CIRT-operaties Coördinatie van de incidentrespons Rapportering aan het managementteam Contactpunt voor CCB, CERT.be en GBA
ICT Security Medewerker	Security Analyst	1 FTE	Dagelijkse monitoring van Wazuh en OpenSearch Triage van alerts en forensisch onderzoek Beheer van DFIR-IRIS casedossiers en IOC-tracking Ontwikkeling en verfijning van custom Wazuh-regels
ICT Systeembeheerder	Systeembeheerder	Gedeeld	Beheer van de SOC-infrastructuur (Wazuh, DataGerry, DFIR-IRIS) Patch management en back-up beheer Isolatie van systemen en herstel conform DRP
ICT Netwerkbeheerder	Netwerkeningenieur	Gedeeld	Beheer van pfSense firewall en netwerksegmentatie Configuratie van firewall rules en VPN Uitvoering van containment-acties: blokkeren van IP-adressen en C2-domeinen
ICT Helpdesk	Eerstelijns meldpunt	1 FTE	Eerstelijns opvang van meldingen van medewerkers Uitvoering van routinetaken: wachtwoordresets, accountblokkering Escalatie naar Security Medewerker of ICT Manager
DPO / Privacy Officer	Privacy Officer	Gedeeld	GDPR-compliance bij alle SOC-activiteiten Coördinatie meldplicht datalekken aan GBA binnen 72 uur Aanspreekpunt bij externe privacy-audits

Managementteam (MT)

Bij significante cyberincidenten (P1 - Kritiek of P2 - Hoog) wordt het managementteam ingeschakeld voor strategisch toezicht en beslissingen over middelen, externe communicatie en patiëntveiligheid.

Functie	MT-rol	Verantwoordelijkheid
Algemeen Directeur (CEO)	Eindverantwoordelijke	Strategische beslissingen, goedkeuring externe communicatie en persberichten
Medisch Directeur	Zorg continuïteit	Klinische beslissingen bij dreiging voor patiëntveiligheid, overschakelen op noodprocedures
CFO	Financiële goedkeuring	Goedkeuring budget voor externe experts, cyberverzekering en herstelkosten
ICT Manager	Technisch advies	Technische briefing van het MT, coördinatie van de CIRT-operaties

6.2 Externe partners

Omdat de interne ICT-afdeling van AZ Herentals beperkt is, worden bij complexe of ernstige incidenten externe partners ingeschakeld. Het is aanbevolen om vooraf contracten te sluiten met gespecialiseerde partijen zodat er geen vertraging is bij een actief incident.

Partner	Contactgegevens	Rol bij incidenten
CERT.be (CCB)	cert@cert.be +32 2 790 33 85	Nationaal meldpunt en adviesorgaan. Verplicht contacteren conform NIS2: vroegtijdige waarschuwing binnen 24 uur.
Externe IR-partner	[E-mail / Telefoon]	Forensisch onderzoek en incident response bij complexe aanvallen (bv. ransomware). Vergroot analysecapaciteit wanneer interne middelen onvoldoende zijn.
GBA	+32 2 274 48 00	Belgische toezichthoudende autoriteit. Verplichte melding bij datalekken met patiëntgegevens binnen 72 uur (GDPR Art. 33).
Federale Politie (FCCU)	+32 2 508 87 11	Aangifte bij strafbare feiten zoals hacking en ransomware. Forensisch correct bewijs bewaren voor juridische procedures.
Leverancier medische systemen	[Per leverancier]	Verplicht contactpunt bij incidenten op medische apparatuur vanwege MDR/IVDR-certificeringsvereisten.

7. SOC infrastructuur en tools

7.1 Netwerksegmentatie en architectuur

Het SOC van AZ Herentals is opgebouwd als een gelaagde beveiligingsomgeving met strikte netwerksegmentatie. De architectuur bestaat uit twee segmenten beheerd via pfSense, met een duidelijke scheiding tussen het SOC-netwerk en het kantoor netwerk.

Segment	IP-bereik	Systemen	Functie
SOC Netwerk (LAN)	192.168.1.0/24	AlmaLinux server (192.168.1.100), Kali console (192.168.1.101)	Beveiligingstools - strikt toegangsbeheer
Office Netwerk (OPT1)	192.168.10.0/24	AD Domain Controller (192.168.10.10), Windows 11 Client	Werkstations en domeingebruikers
WAN / Internet	Extern	Laptop beheerder, externe verbindingen	Extern beheer via pfSense VPN

Wazuh-agents op het Office-segment sturen versleutelde logdata via pfSense-firewallregels naar de Wazuh Manager op het LAN-segment. De beveiligingstools zijn zo volledig geïsoleerd van het kantoor netwerk. Zeek draait op pfSense en inspecteert het netwerkverkeer op de perimeter voor DNS-gebaseerde detectie van Command and Control (C2) communicatie.

7.2 Overzicht van de tools

Tool	Functie	Locatie/poort	Gebruik in het SOC
Wazuh SIEM/EDR	Detectie en monitoring	192.168.1.100 (poort 1514/1515)	Primaire SIEM: verzameling van Windows Event Logs, Syslog en FIM-alerts. Correlatie van events op basis van decoders en rules. Opslag in OpenSearch-index wazuh-alerts.
OpenSearch Dashboards	Visualisatie	Geïntegreerd in Wazuh (poort 443)	6 custom security-visualisaties: logins per dag, foutieve logins per gebruiker, brute force teller, pie chart per zone, gauge-drempelwaarden en alert-overzicht.
DFIR-IRIS	Case management	192.168.1.100:4433	Gestructureerde opvolging van incidenten: casedossiers, IOC-tracking met TLP-classificaties, triage-workflows, taken per dossier. Draait via Docker Compose.
DataGerry CMDB	Asset management	192.168.1.100:80	Centrale IT-asset inventaris (Single Source of Truth). Shadow IT detectie. Logon Hours als asset-attribuut. Koppeling met Wazuh voor asset-context bij alerts.
pfSense Firewall	Firewall / routing	Dedicated VM (192.168.1.1 / 192.168.10.1)	Netwerksegmentatie via VLANs, firewallregels per interface, VPN voor extern beheer, containment-acties bij incidenten (blokkeren van IP-adressen en domeinen).
Zeek	Netwerkinspectie	Op pfSense (cron-job voor logrotatie)	DNS-inspectie op de netwerkperimeter. Genereert conn.log, dns.log en notice.log. Logs worden via remote syslog naar Wazuh doorgestuurd voor correlatie.
Active Directory	Toegangsbeheer	Windows Server 2022 (192.168.10.10)	Gecentraliseerd gebruikers- en groepsbeheer. Logon Hours per tijdzone. Group Policy Objects voor audit logging.

			NTFS-permissies op gedeelde mappen (C:\CompanyData).
OpenVAS (Greenbone)	Vulnerability scanning	AlmaLinux (Docker, GCE-poort 9392)	Periodieke unauthenticated en authenticated kwetsbaarheidsscans. Rapportage als input voor het patch management-proces. Preventief luik naast de detectieve tools.
Kali Linux	Beheersconsole / testomgeving	192.168.1.101 (SOC LAN)	Toegang tot de SOC-tools via de browser. Uitvoeren van gesimuleerde aanvallen voor het testen van detectieregels (bv. dig-commando voor C2-simulatie).

8. Log collectie en dataflow

8.1 Welke logs worden verzameld

Wazuh-agents op de Windows Server (Active Directory) en de Windows 11-client verzamelen de volgende log categorieën:

Categorie	Beschrijving	Windows Event ID	Wazuh-verwerking
Authenticatie	Alle geslaagde en mislukte aanmeldingen	4624, 4625, 4634	Wazuh rule 60106 (geslaagd) en 60122 (mislukt). Basis voor brute force detectie.
Accountbeheer	Aanmaken, wijzigen en verwijderen van accounts	4720, 4726, 4728	Wazuh standaardregels voor account lifecycle monitoring.
Bestandstoegang (FIM)	Toegang tot en wijziging van bestanden in C:\CompanyData	4663, 4656	Wazuh syscheck (File Integrity Monitoring). Realtime alerts bij aanmaken, wijzigen of verwijderen van bestanden.
Audit Policy events	Logon/Logoff, Object Access, Account Logon	Via GPO ingeschakeld	Geconfigureerd via Default Domain Controllers Policy in Group Policy Management.
Systeemgebeurtenissen	Start/stop services, wijzigingen audit policy	System/Security log	Wazuh standaardregels voor systeem-integriteitsmonitoring.
DNS logs (Zeek)	Alle DNS-queries op de netwerkperimeter	Zeek dns.log	Via remote syslog van pfSense naar Wazuh. Gebruikt voor C2-detectie via DNS (rule 300002).
pfSense firewall logs	Geblokkeerde en doorgelaten verbindingen	pfSense syslog	Via remote syslog naar Wazuh. Correlatie met Zeek-alerts voor bevestiging van C2-blokkade.

8.2 Hoe worden logs verzameld

De logcollectie verloopt als volgt:

1. Wazuh-agents worden geïnstalleerd op elke Windows-machine (AD-server en Windows 11 Client) via een PowerShell-installatiescript dat wordt aangeboden vanuit het Wazuh-dashboard (Wazuh > Agents > Deploy new agent).
2. Op elke agent wordt het bestand ossec.conf geconfigureerd met de juiste localfile-secties voor de Windows Event Log-kanalen (Security, System) en de syscheck-sectie voor FIM op C:\CompanyData.
3. De Wazuh-agents sturen versleutelde logdata via TCP op poort 1514 naar de Wazuh Manager op 192.168.1.100.

4. Op pfSense wordt Zeek geïnstalleerd als package. Zeek genereert connection- en DNS-logs die via remote syslog worden doorgestuurd naar de Wazuh Manager op poort 514 (UDP).
5. De Wazuh Manager verwerkt alle inkomende logs via decoders en rules, slaat de resulterende alerts op in de OpenSearch-index wazuh-alerts-* en maakt ze beschikbaar via OpenSearch Dashboards.

8.3 Dataflow van event tot alert

De volledige dataflow van een ruwe Windows-gebeurtenis tot een zichtbare alert in het SOC-dashboard verloopt als volgt:

Stap	Component	Actie	Resultaat
1	Windows OS (AD-server of client)	Genereren van een Windows Event (bv. 4625 - mislukte login)	Event staat in het Windows Security Event Log
2	Wazuh Agent	Agent leest het event uit het lokale Event Log (localfile syscheck)	Event wordt versleuteld verzonden naar de Wazuh Manager
3	Wazuh Manager (AlmaLinux)	Manager decodeert het event en vergelijkt met alle actieve rules (standaard + custom)	Bij match met een rule: alert aangemaakt met level, rule ID en beschrijving
4	OpenSearch / wazuh-alerts index	Alert wordt opgeslagen in de OpenSearch-index	Alert beschikbaar voor zoeken, filteren en visualisatie
5	OpenSearch Dashboards	Dashboard toont de alert realtime in de beveiligingsvisualisaties	SOC-analist ziet de alert in het dashboard
6	SOC-analist	Triage van de alert: false positive of reëel incident?	Bij reëel incident: case aangemaakt in DFIR-IRIS met IOCs en taken

9. Monitoring en detectie

9.1 Dagelijkse monitoring

De ICT Security Medewerker start elke werkdag met een review van de Wazuh-alerts van de afgelopen 24 uur via het OpenSearch-beveiligingsdashboard. Het dashboard toont 6 custom visualisaties die dagelijks worden gemonitord:

- **Logins per dag** (Line Chart): toont het aantal geslaagde Windows-logins per dag. Afwijkingen in het patroon (bv. piek buiten kantooruren) worden onmiddellijk gemarkeerd.
- **Foutieve logins per gebruiker** (Vertical Bar): toont mislukte aanmeldingen per account per dag. Identificeert doelwitaccounts bij brute force-aanvallen.
- **Brute Force Alert teller** (Metric): toont het aantal keren dat rule 100100 getriggerd werd (10+ mislukte logins in 300 seconden).
- **Logins per Zone** (Pie Chart): verdeling van policy violations per gebruikersgroep (EU vs US). Gebaseerd op rules 60122, 100101 en 100102.
- **3 foutieve logins drempel** (Gauge): meter voor de lage drempelwaarde (rule 60122). Groen 0-3, oranje 3-10, rood 10+.
- **10 foutieve logins drempel** (Gauge): meter voor de brute force drempelwaarde (rule 100100). Triggert bij 10+ mislukte logins.

9.2 Detection rules en alerts

Naast de standaard Wazuh-regelsets zijn 5 custom XML-regels ontwikkeld specifiek voor de AZ Herentals-omgeving. Deze zijn opgeslagen in local_rules.xml op de Wazuh Manager. Alle regels zijn gemapped op het MITRE ATT&CK-framework.

Rule ID	Naam	Level	MITRE ATT&CK	Detectielogica
100100	Brute Force Detectie	10	T1110 Brute Force	10 keer Event ID 4625 (mislukte login) binnen 300 seconden op hetzelfde account in het domein lab.local. Triggert bij gecoördineerde wachtwoordaanvallen.
100101	Policy Violation US User	8	T1078 Valid Accounts	US-gebruiker (John_us) meldt zich aan buiten Eastern Time kantooruren. Verboden periode: 00:00-14:00 CET (equivalent van voor 08:00 ET). Detecteert ongeoorloofd gebruik buiten werktijden.
100102	Kritiek US Admin buiten uren	12	T1078 Valid Accounts	US administrator (admin_Trump) meldt zich aan buiten kantooruren. Hogere severity dan 100101 omdat een gecompromitteerd adminaccount directe toegang geeft tot alle systemen.
300001	Credential Compromise correlatie	10	T1110 + T1078	5 mislukte logins gevolgd door een geslaagde login van hetzelfde account binnen 2 minuten. Combineert brute force (T1110) met succesvol gebruik van gestolen credentials (T1078).
300002	Ransomware C2 Contact DNS	15	T1071.004 DNS	DNS-query naar bekende C2-indicator (pastebin.com) gecorreleerd met pfSense-blokkade via Zeek. Level 15 = hoogste prioriteit. Directe activatie CIRT vereist.

9.3 MITRE ATT&CK mapping

Alle detectieregels zijn gekoppeld aan het MITRE ATT&CK-framework. Dit framework biedt een gestandaardiseerde classificatie van aanvalstactieken en -technieken, waardoor vergelijking met andere organisaties en threat intelligence-bronnen mogelijk wordt.

MITRE Techniek	Beschrijving	Detectie in SOC AZ Herentals	Wazuh Rule
T1110 - Brute Force	Herhaalde inlogpogingen om een account te compromitteren	10+ mislukte logins in 300 seconden via Event ID 4625	Rule 100100
T1078 - Valid Accounts	Gebruik van legitieme accounts op ongeoorloofd tijdstip of vanuit onbekende locatie	Login buiten Logon Hours van US-gebruikers (CET 00:00-14:00)	Rules 100101 en 100102
T1071.004 - DNS	Gebruik van DNS voor command and control communicatie	DNS-query naar bekende C2-domein (pastebin.com) via Zeek-inspectie op pfSense	Rule 300002
T1003.001 - LSASS Memory	Credential dumping via LSASS (bv. Mimikatz)	Detectie via Wazuh EDR bij uitvoering van Mimikatz (scenarisch geïmplementeerd)	Rule 100200
T1567.002 - Exfiltratie via webdiensten	Upload van gevoelige bestanden naar cloudopslagdiensten zoals Dropbox	Detectie van Dropbox-endpoint connecties (DLP-scenario)	Rule 100300

10. Escalatie en incidentrespons

10.1 Escalatiestructuur

Alerts worden verwerkt op basis van het Wazuh-alarmniveau en de bijhorende incidentprioriteit. De onderstaande tabel toont de volledige escalatiestructuur.

Wazuh Level	Prioriteit	Reactietijd	Voorbeelden	Wie handelt af
Level 1-7	P4 - Laag	Binnen 24 uur	Mislukte logins, USB-gebruik	ICT Security Medewerker - dagelijkse review
Level 8-11	P3 - Gemiddeld	Binnen 4 uur	Phishing, FIM alert, policy violation	ICT Security Medewerker - escalatie naar ICT Manager indien nodig
Level 12-14	P2 - Hoog	Binnen 1 uur	Admin-account gecompromitteerd, brute force geslaagd	ICT Manager onmiddellijk informeren - CIRT-activatie overwogen
Level 15	P1 - Kritiek	Binnen 15 min	Ransomware C2, datalek patiëntgegevens, uitval EPD	Onmiddellijke CIRT-activatie - directie informeren - externe partners inschakelen

10.2 Koppeling met het CIRP

De escalatiestructuur van het SOC is volledig geïntegreerd met het Cyber Incident Response Plan (CIRP) van AZ Herentals. Het CIRP definieert de zes NIST-fasen die het SOC volgt bij elk incident van niveau P2 of hoger:

- **Fase 1:** Voorbereiding: beleid, procedures en tooling (Wazuh, DFIR-IRIS) zijn klaargezet. Offline noodcontactlijsten zijn beschikbaar.
- **Fase 2:** Detectie en analyse: Wazuh-alert wordt gevalideerd door de ICT Security Medewerker. CIRT wordt geactiveerd bij P1 of P2.
- **Fase 3:** Indamming (Containment): betrokken account geblokkeerd in Active Directory, bron-IP gefilterd via pfSense, systeem geïsoleerd indien nodig.
- **Fase 4:** Eradicatie: malwareverwijdering, wachtwoordreset van alle betrokken accounts, controle op persistence-mechanismen.
- **Fase 5:** Herstel: systemen worden stapsgewijs teruggezet vanuit geverifieerde back-ups. Verhoogde Wazuh-monitoring gedurende 14 dagen na herstel.
- **Fase 6:** Lessons Learned: binnen 5 werkdagen na het incident een evaluatievergadering. CIRP en Wazuh-regels worden bijgewerkt op basis van de bevindingen.

11. Case management met DFIR-IRIS

DFIR-IRIS (Digital Forensics Incident Response Information System) is geïmplementeerd als het centrale case management platform van het SOC. Het sluit de SOC-cyclus: detectie via Wazuh wordt gevolgd door gestructureerde incident response en documentatie in DFIR-IRIS.

DFIR-IRIS draait via Docker Compose op de AlmaLinux-server op poort 4433. Het biedt volledige ondersteuning voor GDPR- en NIS2-compliance documentatie. Toegang: <https://192.168.1.100:4433> (gebruiker: administrator).

De volgende cases zijn geïmplementeerd voor AZ Herentals:

Case ID	Naam	Severity	Status	MITRE	IOCs en assets
AZH-001	Brute Force Credential Compromise op Active Directory	HIGH	Open	T1110	IP 192.168.1.50 (TLP:RED), domein lab.local, Asset: DC01-AZHerentals
AZH-002	Mimikatz detectie via WeTransfer download	CRITICAL	Scenarisch	T1003.001	Hash setup.exe, wetransfer.com, LSASS credential dump
AZH-003	Upload vertrouwelijk document naar Dropbox (DLP)	HIGH	Scenarisch	T1567.002	dropbox.com endpoints, patiëntgegevens exfiltratie, GDPR-meldplicht actief
AZH-004	Ransomware C2 Contact via DNS	CRITICAL	Open	T1071.004	pastebin.com (C2-domein), IP 192.168.1.50, Linked case: AZH-001

Opmerking: bij het aanmaken van IOCs in DFIR-IRIS werd een bekende GUI-bug vastgesteld waarbij de 'Add IOC'-knop het formulier niet opende. Dit probleem is opgelost door IOCs toe te voegen via de DFIR-IRIS REST API vanuit de terminal.

12. Threat intelligence integratie

Threat intelligence wordt op twee niveaus geïntegreerd in het SOC van AZ Herentals:

12.1 Strategische threat intelligence

Op strategisch niveau worden de volgende bronnen gebruikt om de custom Wazuh-regels up-to-date te houden en nieuwe dreigingen te anticiperen:

- ENISA Threat Landscape for the Health Sector - jaarlijks rapport over dreigingen specifiek voor de zorgsector. Wordt gebruikt als basis voor de dreigingsanalyse van AZ Herentals.
- CERT.be advisories en CCB-publicaties - Belgische dreigingsinformatie en aanbevelingen voor NIS2-entiteiten.
- MITRE ATT&CK-updates - nieuwe tactieken en technieken worden beoordeeld op relevantie voor de AZ Herentals-omgeving.
- CyFun-framework updates - jaarlijkse updates van het CCB CyberFundamentals Framework worden verwerkt in het beleid.

12.2 Operationele threat intelligence

Op operationeel niveau worden concrete indicatoren van compromis (IOCs) verwerkt in de SOC-tools:

- IOCs (IP-adressen, domeinen, hashes) worden opgenomen in DFIR-IRIS cases met TLP-classificaties (TLP:RED, TLP:AMBER) voor gecontroleerde verspreiding.
- Bekende C2-domeinen worden als detectiebasis gebruikt in Zeek-rules en Wazuh custom rules (bv. pastebin.com in rule 300002).
- Wekelijkse threat intelligence-updates worden besproken tijdens de SOC-vergadering. Nieuwe IOCs worden indien relevant omgezet in custom Wazuh-regels.
- Linked cases in DFIR-IRIS verbinden gerelateerde incidenten via gedeelde IOCs (bv. IP 192.168.1.50 is gedeeld tussen AZH-001 en AZH-004).

13. SOC werkwijze

13.1 Dagelijkse werkwijze

Elke werkdag doorloopt de ICT Security Medewerker de volgende stappen:

- Ochtend (08u00): Review van de OpenSearch Security Dashboard - controle van alle alerts van de afgelopen 24 uur. Beoordeling van de 6 visualisaties op afwijkingen.
- Triage: elke alert wordt beoordeeld als false positive of reëel incident op basis van context (gebruiker, tijdstip, IP-adres, frequentie).
- False positives worden gedocumenteerd en eventueel gebruikt om de Wazuh-rules te verfijnen (drempelwaarden aanpassen, whitelists bijwerken).
- Rele incidenten worden aangemaakt als case in DFIR-IRIS met: incidentomschrijving, severity, betrokken assets, IOCs en initieel actieplan.
- P1 en P2 incidenten: onmiddellijke melding aan de ICT Manager en activatie van het CIRP.
- Einde dag: controle van de DataGerry CMDB op nieuwe of niet-geregistreerde assets (Shadow IT-detectie).

13.2 Wekelijkse vergadering

Het SOC-team houdt een wekelijkse vergadering met de volgende vaste agendapunten:

- Review van alle false positives van de afgelopen week en evaluatie of regeloptimalisatie nodig is
- Bespreking van geëscaleerde incidenten en lessons learned
- Threat intelligence-updates op basis van recente ENISA- en CERT.be-rapporten
- Status van openstaande DFIR-IRIS casedossiers en voortgang van herstelacties

- Update van de DataGerry CMDB-inventaris bij nieuwe, gewijzigde of buiten gebruik gestelde assets
- Evaluatie van de CyFun-maturiteitsscore en identificatie van verbeterpunten

13.3 Periodieke taken

Frequentie	Taak	Verantwoordelijke en beschrijving
Dagelijks	Alert review en dashboard monitoring	ICT Security Medewerker - review van OpenSearch Dashboard en triage van nieuwe Wazuh-alerts
Wekelijks	SOC-vergadering	ICT Manager + ICT Security Medewerker - threat intelligence, false positive review, caseupdate
Maandelijks	OpenVAS vulnerability scan	ICT Security Medewerker - volledige scan van alle geregistreerde assets in DataGerry CMDB
Maandelijks	Back-up hersteltest	Systeembeheerder - test van EPD-, Wazuh- en DFIR-IRIS-back-ups conform het DRP
Kwartaal	Shadow IT-scan	ICT Security Medewerker - herhaalde inventarisatie via DataGerry CMDB om ongeregistreeerde systemen op te sporen
Jaarlijks	CyFun self-assessment	ICT Manager - evaluatie van de beveiligingsmaturiteit conform het CyberFundamentals Framework van het CCB
Jaarlijks	Tabletop oefening / IR-drill	ICT Manager + volledig CIRT-team - gesimuleerde incidentrespons oefening (bv. ransomware-scenario)
Jaarlijks	Review beleidsdocumenten	ICT Manager + DPO - herziening van CIRP, BCP, DRP en dit document op basis van nieuwe dreigingen en lessons learned

14. Rapportering en communicatie

Alle cyberincidenten en hun afhandeling worden gedocumenteerd en gerapporteerd. AZ Herentals is als zorginstelling onderworpen aan specifieke meld- en rapportageverplichtingen.

Type melding	Aan wie	Deadline	Verantwoordelijke en beschrijving
Datalek patientgegevens (GDPR)	GBA (+32 2 274 48 00)	Binnen 72 uur (Art. 33 AVG)	DPO coördineert de melding. Bij hoog risico ook melding aan betrokken personen (Art. 34).
Significante cyberaanval (NIS2)	CCB / CERT.be (cert@cert.be)	Waarschuwing < 24 uur, volledig < 72 uur	ICT Manager maakt melding via nis-incident.be. Er hoeft niet gewacht te worden tot alle informatie beschikbaar is.
Strafbaar feit (hacking, ransomware)	Federale Politie / FCCU	Zo snel mogelijk na bevestiging	CEO of ICT Manager doet aangifte. Forensisch bewijs bewaren voor gerechtelijke procedures.
Incident op medische apparatuur	FAMHP (FAGG)	Conform MDR/IVDR-vereisten	Medisch Directeur en ICT Manager coördineren de melding.
Interne rapportering	Directie / MT	Jaarlijks overzicht + per P1-incident	ICT Manager rapporteert jaarlijks alle incidenten aan de directie en risico comités.

15. Training en oefeningen

Training en regelmatig oefenen zijn essentieel voor een effectief SOC. De CyFun self-assessment wees Security Awareness Training aan als het zwakste domein (score 2.0/5), wat het belang van een gestructureerd trainingsprogramma onderstreept.

- Nieuwe SOC-medewerkers: verplichte onboarding met introductie tot alle SOC-tools (Wazuh, DFIR-IRIS, DataGerry, pfSense, OpenVas) en de beleidsdocumenten (CIRP, BCP, DRP, dit document).
- Jaarlijkse tabletop-oefening: het volledige CIRT-team doorloopt een gesimuleerd incident-scenario (bv. ransomware-aanval op EPD). Doel: valideren van de CIRT-procedures en identificeren van lacunes.
- Phishing-simulaties: periodieke gesimuleerde phishing-campagnes gericht op zorgpersoneel om security awareness te verhogen. Resultaten worden gerapporteerd aan de ICT Manager.
- Wazuh rule-testing: na elke wijziging aan custom rules worden gesimuleerde testgevallen uitgevoerd (bv. brute force-simulatie via Kali Linux) om de correcte werking van de detectie te valideren.
- Post-incident training: na elk P1- of P2-incident wordt de lessons learned-sessie gebruikt als leermoment voor het volledige CIRT-team.

16. Definities en afkortingen

Afkorting / Term	Omschrijving
AVG / GDPR	Algemene Verordening Gegevensbescherming (EU) 2016/679
CCB	Centre for Cybersecurity Belgium
CERT.be	Belgian Computer Emergency Response Team (onderdeel CCB)
CIRP	Cyber Incident Response Plan
CIRT	Cyber Incident Response Team
CMDB	Configuration Management Database - centrale inventaris van IT-assets
C2	Command and Control - communicatiekanaal tussen malware en aanvaller
DPO	Data Protection Officer: Functionaris Gegevensbescherming
DRP	Disaster Recovery Plan
EDR	Endpoint Detection and Response
EPD	Elektronisch Patientendossier
FIM	File Integrity Monitoring - bewaking van bestandswijzigingen
GBA	Gegevensbeschermingsautoriteit (Belgische toezichthouder GDPR)
IOC	Indicator of Compromise - technisch kenmerk van een aanval (IP, domein, hash)
IoMT	Internet of Medical Things - netwerk-verbonden medische apparatuur
IR	Incident Response
MT	Managementteam
NIS2	Network and Information Security Directive 2 (EU) 2022/2555
PACS	Picture Archiving and Communication System - medische beeldvorming
RPO	Recovery Point Objective: maximaal toelaatbaar dataverlies

RTO	Recovery Time Objective: maximale hersteltijd
SIEM	Security Information and Event Management
SOC	Security Operations Center
SPOC	Single Point of Contact
FTE	Full-Time Equivalent
TLP	Traffic Light Protocol - classificatiesysteem voor het delen van dreigingsinformatie